HACKER WOMEN COUNCIL

Actividad de Hacking Ético
OWASP ZAP

Exploración web · Análisis de alertas · Hallazgo técnico

Nombre y apellido	Alondra Juliana Gadea
Fecha de realización	22/10/2026
Herramienta	OWASP ZAP
Aplicación evaluada	Gin & Juice Shop
URL objetivo	https://ginandjuice.shop/

Contenido

Objetivo de la actividad: 2
1. Explora la aplicación 2
1.1 Página principal 2
1.2 Inicio de sesión 4
1.3 Sección de productos 5
1.4 Búsqueda de productos 7
1.5 Carrito de productos 8
1.6 Perfil de usuario 10
2. Alertas encontradas 12
2.1 Hallazgo 1 12
2.2 Hallazgo 2 12
2.3 Hallazgo 3 13
3. Documenta un hallazgo principal 15
Validación del hallazgo 16
4. Mis conclusiones: 17
4.1 ¿Qué aprendí? 17
4.2 ¿Qué fue lo más retador? 17
4.3 ¿Qué revisaría a continuación? 17
5. Resumen final del reporte 18

Objetivo de la actividad:

Esta actividad tendrá como objetivo analizar la pagina citada y determinar el tráfico, vulnerabilidades y configuraciones de la web.

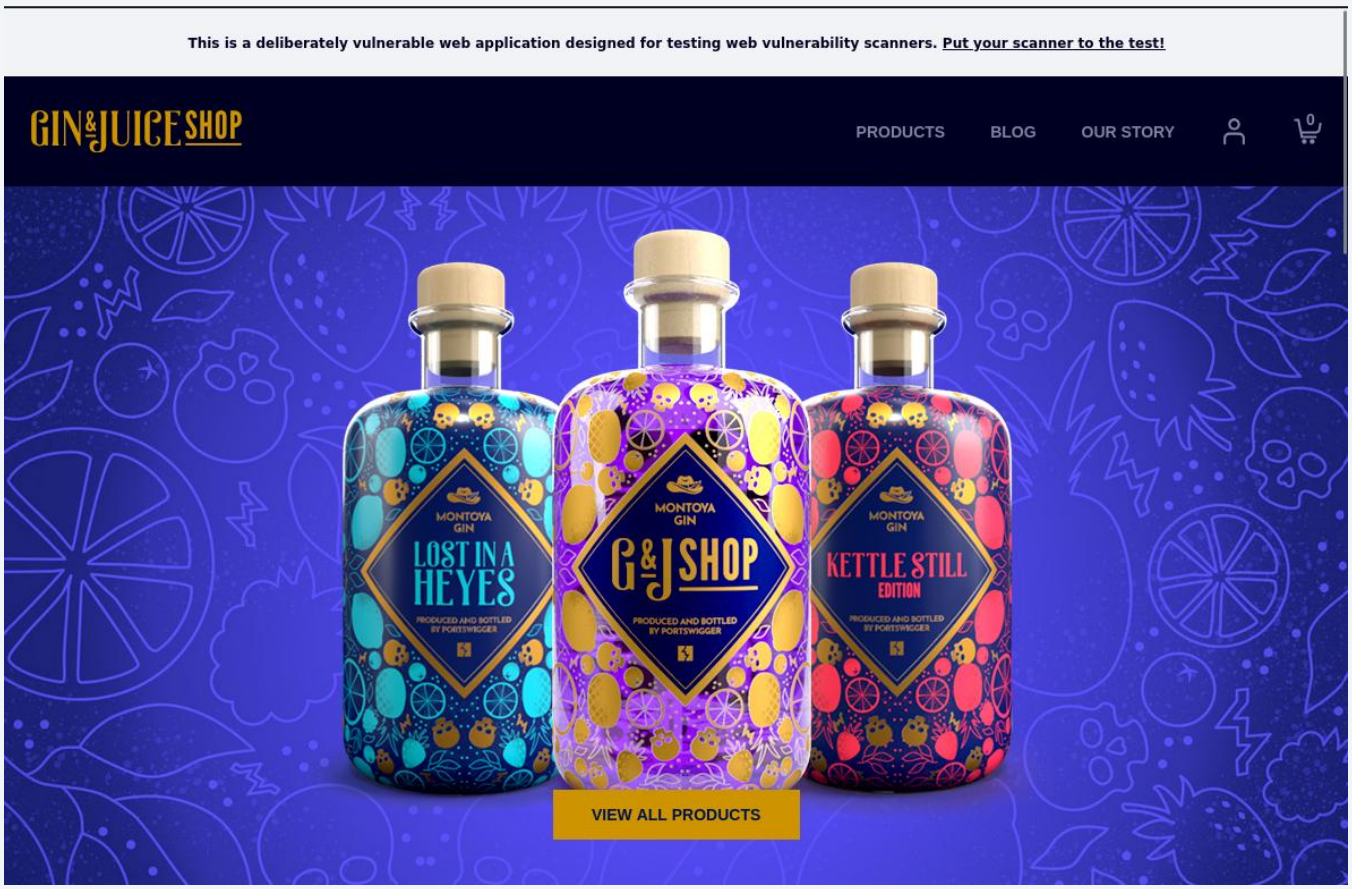
1. Explora la aplicación

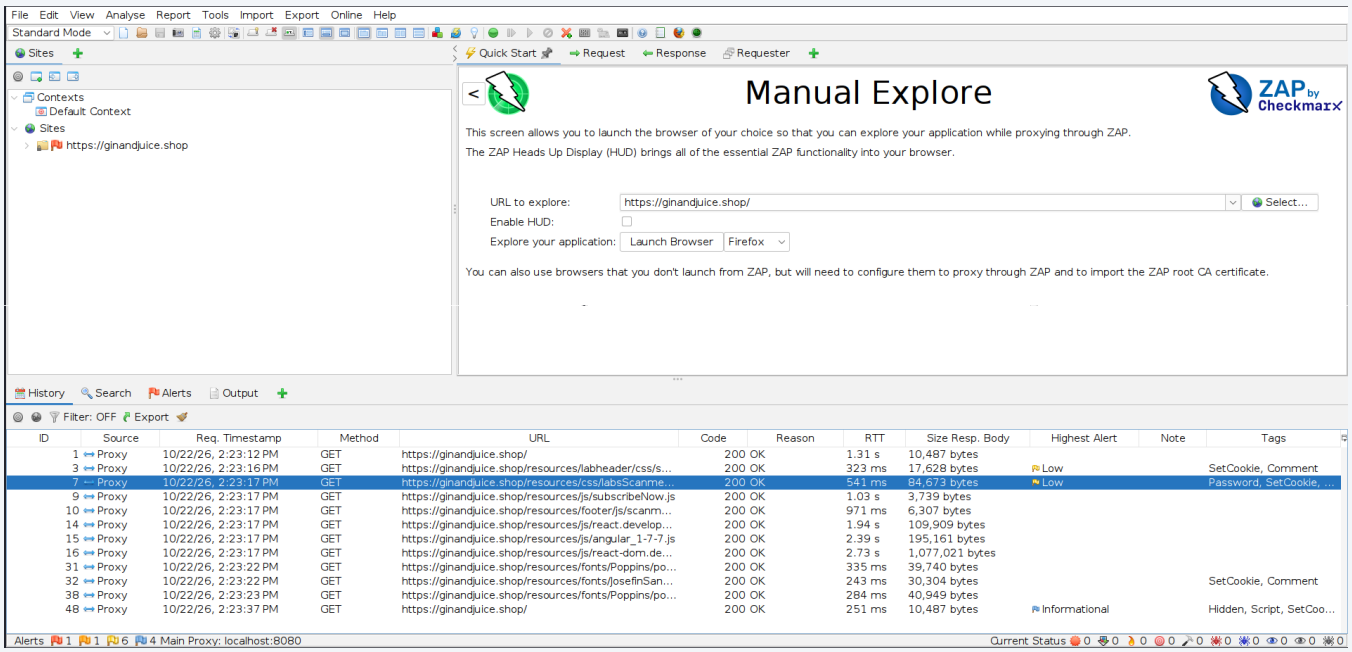
Luego de explorar la aplicación dejo detallado en 5 planillas algunas partes de la aplicación y mis hallazgos.

1.1 Página principal

Sección / funcionalidad	Página principal
URL exacta	https://ginandjuice.shop/
Acción realizada	Acceso a la página de inicio
Resultado observado	El servidor respondió satisfactoriamente a la solicitud de la página principal. Durante la navegación, ZAP registró solicitudes adicionales a recursos CSS, JavaScript y

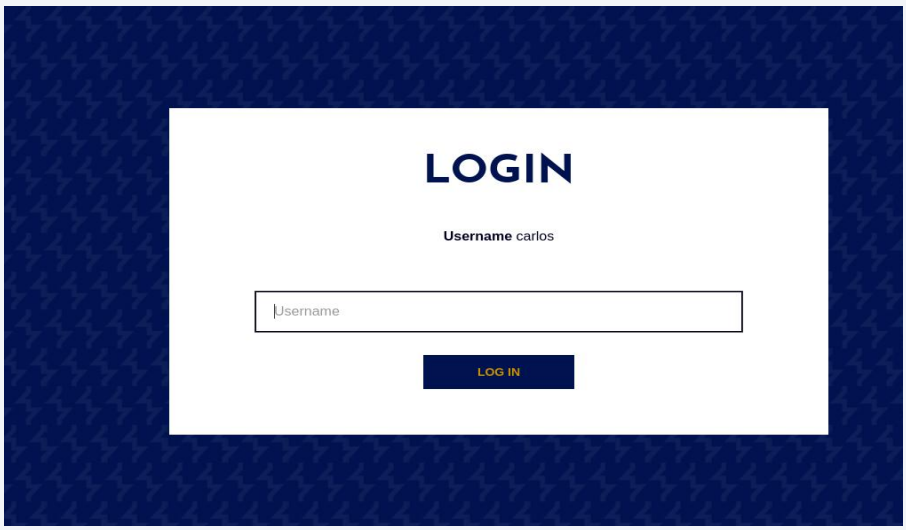
	fuentes tipográficas utilizados por la aplicación.
Método HTTP	GET
Código de respuesta	200 OK
Observaciones	Se identificaron múltiples solicitudes HTTP asociadas a la carga de recursos de la página. También se observan indicadores relacionados con posibles alertas de ZAP, que deberán analizarse por separado para determinar su significado. Las alertas están ordenadas por 1 vulnerabilidad alta, 1 media, 6 bajas y 4 relacionadas a información baja.

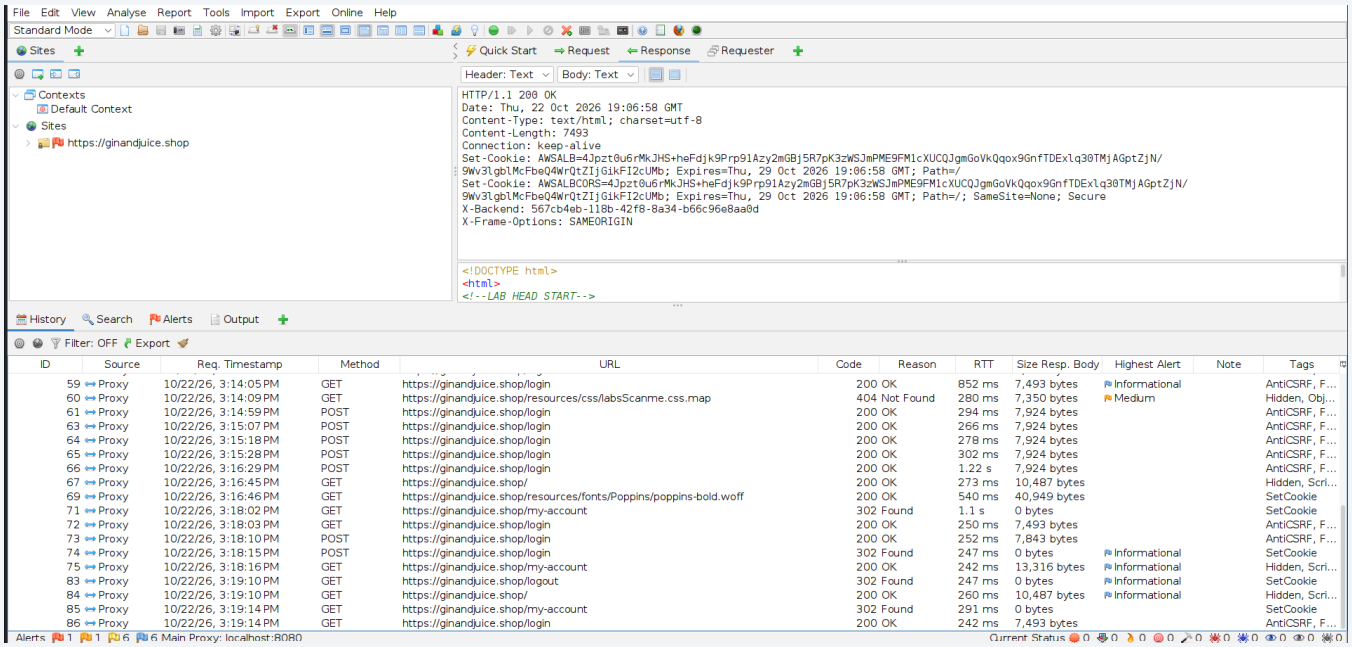




1.2 Inicio de sesión

Sección / funcionalidad	Inicio de sesión
URL exacta	https://ginandjuice.shop/login
Acción realizada	Me dirigí a la página de login e inicié sesión con el usuario y password de prueba.
Resultado observado	El servidor inicio la sesión correctamente mostrando la sección de 'mi cuenta'.
Método HTTP	GET, POST
Código de respuesta	200 OK
Observaciones	Se encontraron alertas medianas con confianza alta en cuanto a la configuración de la página, Si la política está ausente o es demasiado permisiva, podría aumentar la exposición a ciertos ataques que ejecutan o cargan contenido no autorizado. El impacto depende de la configuración y de las demás defensas de la aplicación.

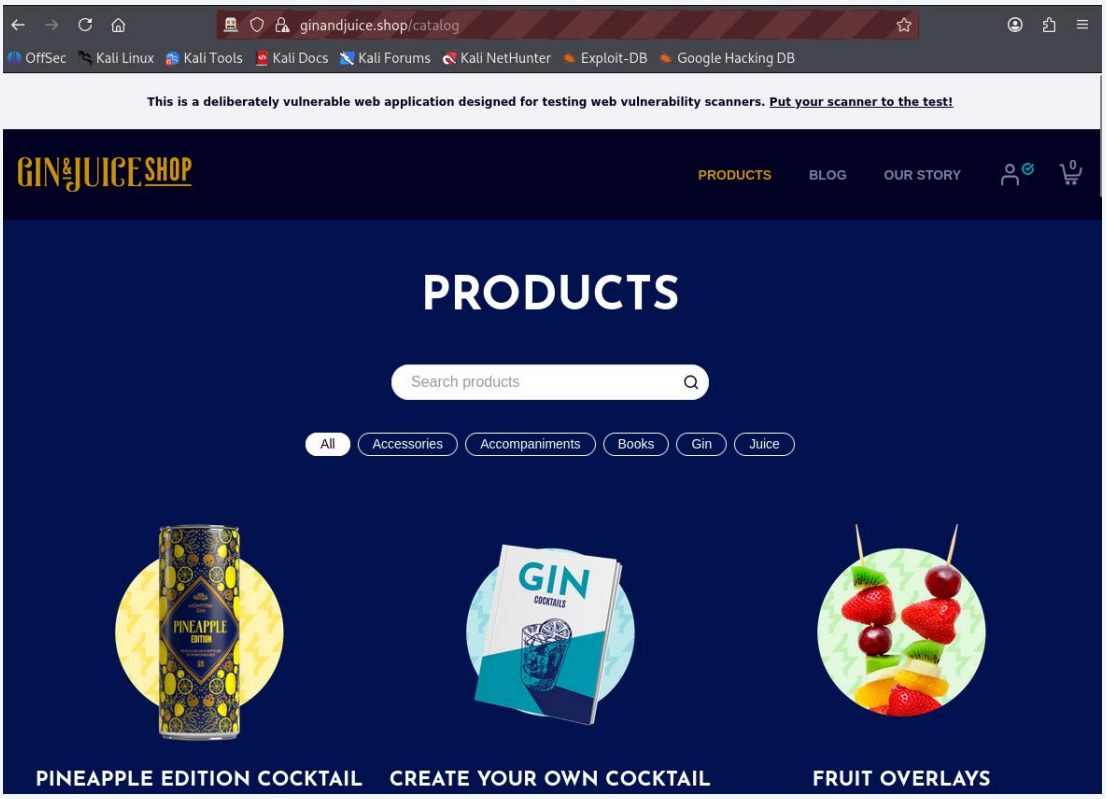


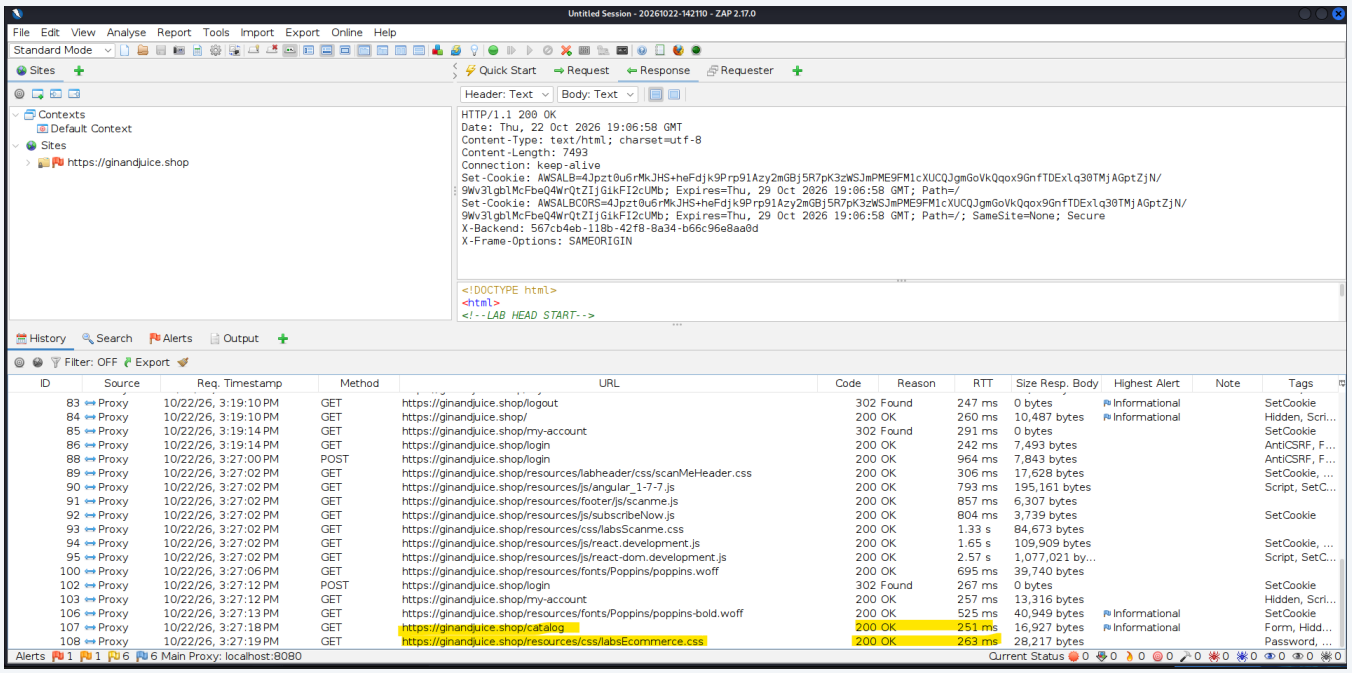


1.3 Sección de productos

Sección / funcionalidad	Sección de productos
URL exacta	https://ginandjuice.shop/catalog
Acción realizada	Acceso a la solapa de productos
Resultado observado	La pagina mostro una lista de productos y una barra de filtros para buscar elementos.
Método HTTP	GET
Código de respuesta	200 OK
Observaciones	El servidor devolvió respuestas correctas ante las consultas GET realizadas sobre la sección de catálogo. Durante el análisis con OWASP ZAP se identificaron algunas alertas de tipo informativo relacionadas principalmente con configuraciones y medidas de seguridad

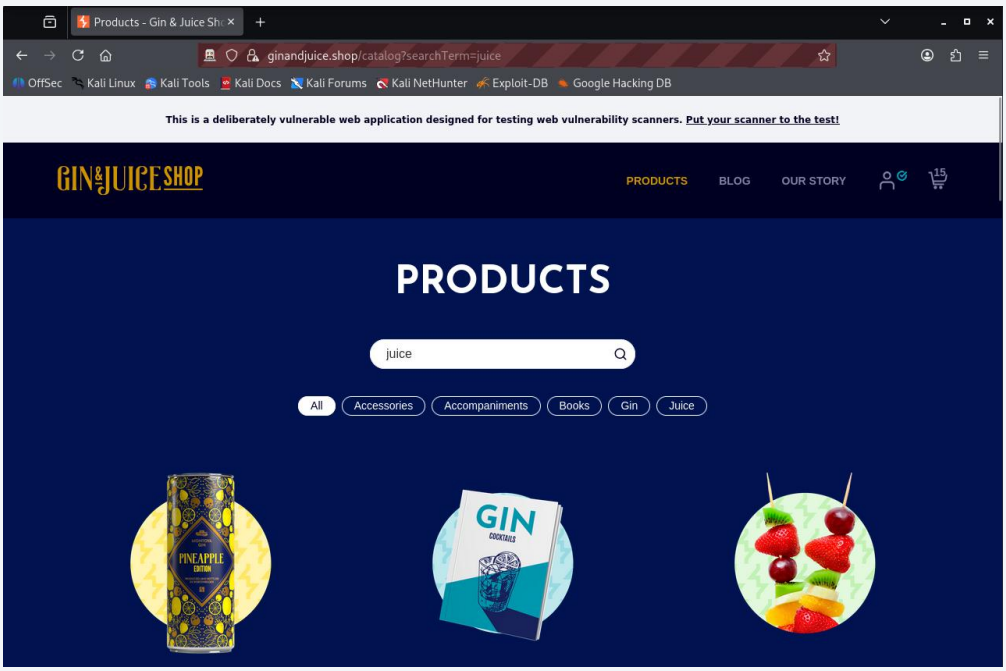
	adicionales, las cuales no fueron clasificadas por la herramienta como incidentes de seguridad por sí mismas. También se identificaron vulnerabilidades de riesgo medio. Entre ellas, se detectó una alerta relacionada con la ausencia de un mecanismo Anti-CSRF en el formulario utilizado para la consulta de stock de los productos. ZAP identificó que dicho formulario utiliza una solicitud HTTP POST y no contiene un token Anti-CSRF reconocido. Esta condición podría representar un riesgo de Cross-Site Request Forgery (CSRF) si la operación pudiera ser ejecutada por un tercero aprovechando la sesión de un usuario y si no existieran otros mecanismos de protección. Debido a que la confianza asignada por ZAP para esta alerta es baja, el hallazgo debe considerarse como una condición a validar y no como una vulnerabilidad explotable confirmada. Asimismo, se detectó una vulnerabilidad de riesgo medio y alta confianza relacionada con la ausencia del encabezado Content-Security-Policy (CSP) en la respuesta de la sección de catálogo. La ausencia de este encabezado implica que la aplicación no está utilizando esta capa adicional de protección para restringir las fuentes desde las cuales el navegador puede cargar determinados recursos. Esto puede aumentar la exposición ante determinados escenarios de ataques de inyección de contenido, incluyendo XSS, aunque la ausencia de CSP no implica por sí misma que exista una vulnerabilidad XSS. En conjunto, los resultados muestran que la funcionalidad principal del catálogo responde correctamente, pero existen configuraciones de seguridad que podrían fortalecerse para reducir la superficie de ataque y mejorar las defensas de la aplicación.

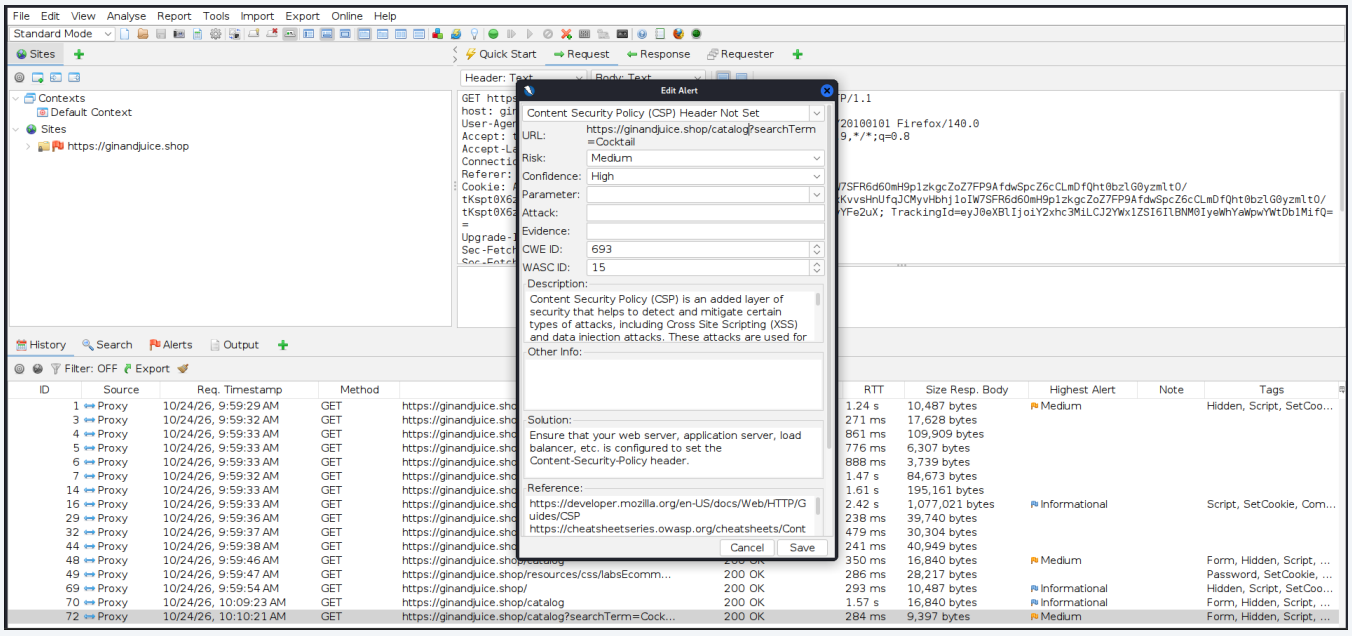




1.4 Búsqueda de productos

Sección / funcionalidad	Búsqueda de productos
URL exacta	https://ginandjuice.shop/catalog?searchTerm=juice
Acción realizada	Realice una búsqueda de productos. En este caso con título 'Juice'
Resultado observado	La aplicación devolvió los productos que contuvieran la palabra juice dentro de alguna parte de su texto.
Método HTTP	GET
Código de respuesta	200 OK
Observaciones	La página devuelve productos relacionados a la palabra. En las búsquedas se ve una alerta media relacionada a lo antes mencionado sobre la configuración de Content-Security-Policy (CSP) la cual debería corregirse.

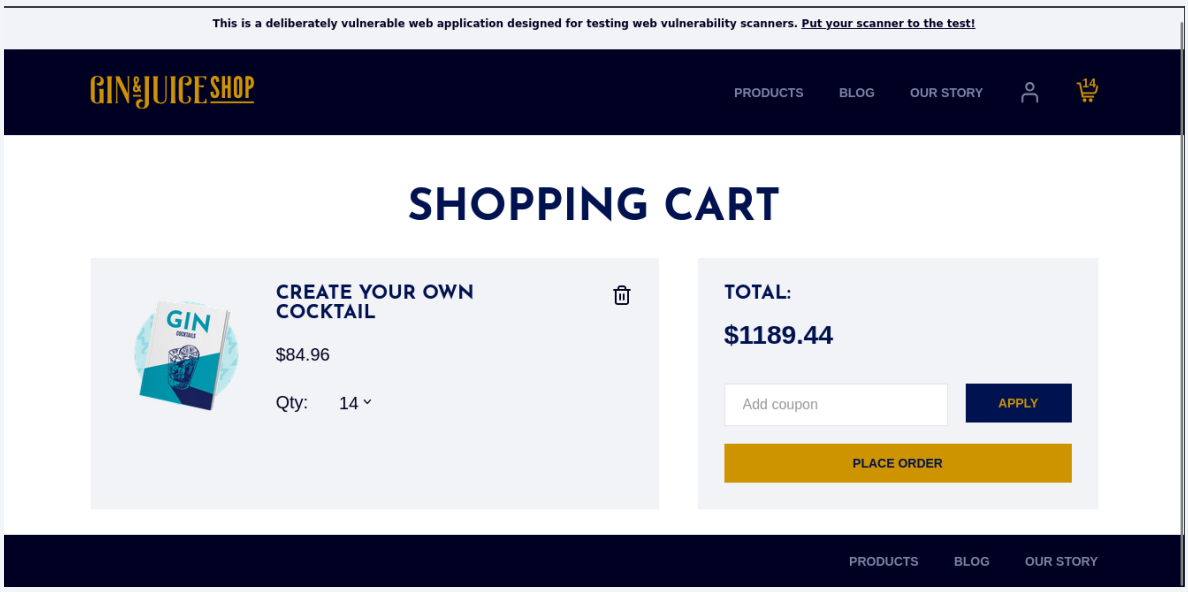


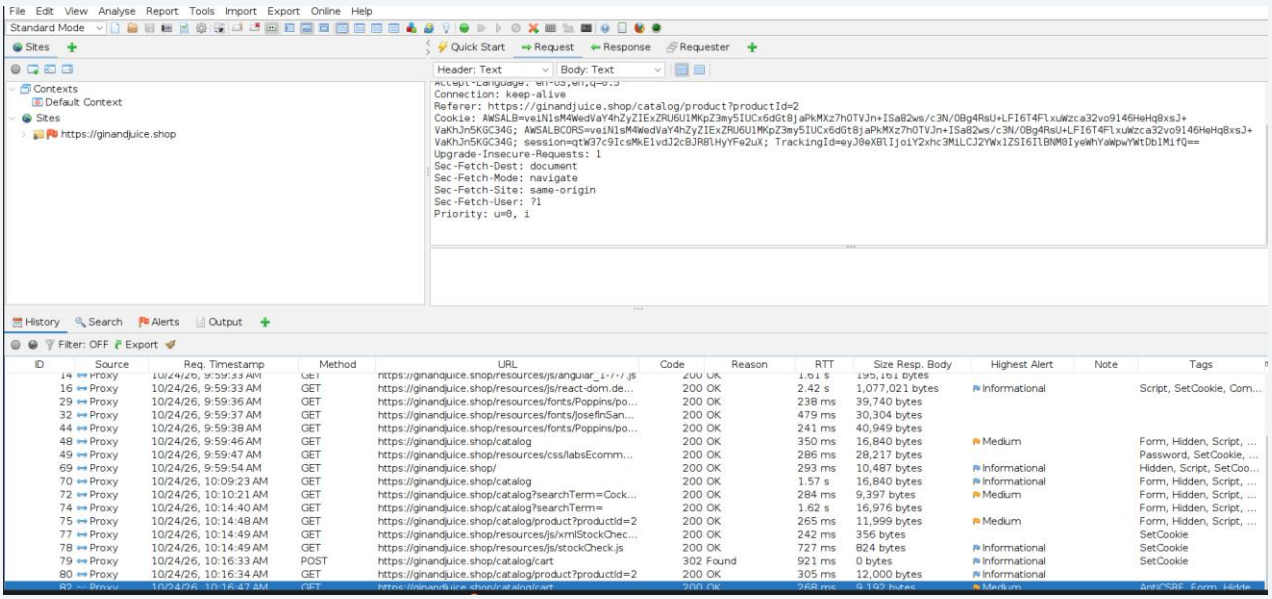


1.5 Carrito de productos

Sección / funcionalidad	Carrito de compras
URL exacta	https://ginandjuice.shop/catalog/cart
Acción realizada	Se agregaron distintos productos al carrito de compras para comprobar el funcionamiento de la incorporación de artículos y el comportamiento de las solicitudes HTTP durante el proceso. Se observó que, antes de agregar un producto,

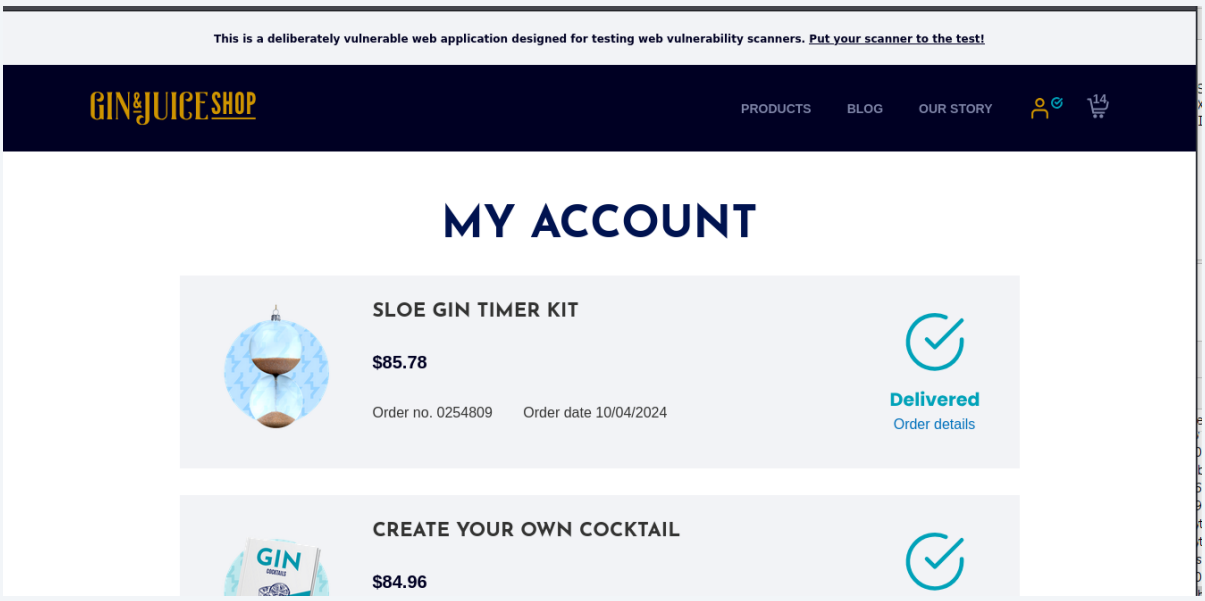
	la aplicación realizaba una solicitud al servicio de validación de stock y posteriormente continuaba con la operación correspondiente.
Resultado observado	La aplicación agregó correctamente los productos seleccionados al carrito. Durante las pruebas se observaron solicitudes HTTP GET y POST, con respuestas 200 OK y redirecciones 302 Found. El comportamiento observado fue compatible con el flujo esperado de navegación y gestión del carrito.
Método HTTP	GET y POST
Código de respuesta	200 OK, 302 FOUND
Observaciones	Durante el análisis con OWASP ZAP se identificó una alerta informativa denominada *Session Management Response Identified*, relacionada con la detección de la cookie AWSALBCORS. Esta alerta no constituye por sí misma una vulnerabilidad y no requiere una corrección específica. Asimismo, se detectó una alerta de riesgo medio y confianza baja denominada *Absence of Anti-CSRF Tokens*. La herramienta identificó un formulario que envía solicitudes POST al endpoint del carrito sin encontrar un token Anti-CSRF reconocido. Esta condición representa un posible riesgo que requiere validación adicional para determinar si la operación puede ser ejecutada mediante una solicitud no deseada y si existen otros mecanismos de protección. Se recomienda revisar las medidas de protección CSRF aplicadas a las operaciones del carrito y verificar la configuración de las cookies y las validaciones realizadas por el servidor. Las alertas detectadas deben evaluarse según su evidencia y su impacto potencial, sin considerar que su presencia confirma automáticamente la explotación de una vulnerabilidad.

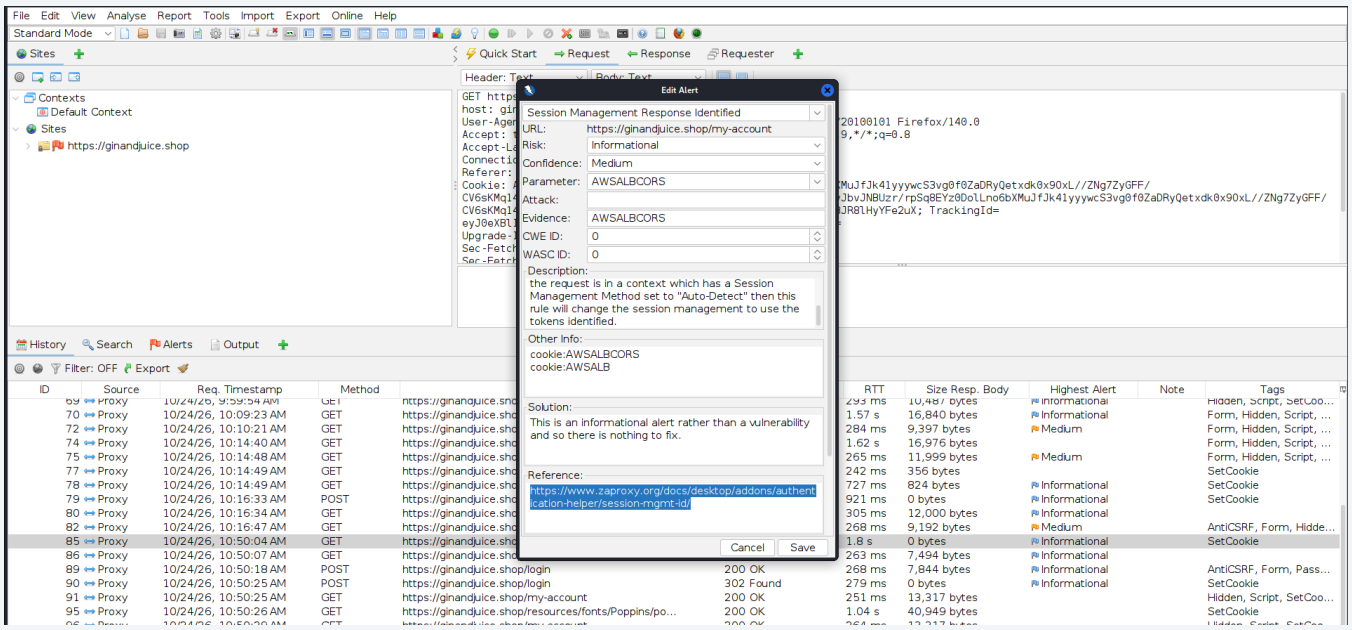




1.6 Perfil de usuario

Sección / funcionalidad	Perfil de usuario / Mi cuenta.
URL exacta	https://ginandjuice.shop/my-account
Acción realizada	Se inició sesión en la aplicación y, posteriormente, se ingresó a la sección «Mi cuenta» para observar la información que mostraba la página y analizar las respuestas HTTP generadas durante la navegación.
Resultado observado	La página respondió correctamente y mostró una lista de productos asociados a las compras realizadas por el usuario. Sin embargo, no se visualizaron datos habituales del perfil, como el nombre de usuario, el correo electrónico u otra información personal de la cuenta.
Método HTTP	GET
Código de respuesta	200 OK
Observaciones	Durante el análisis con OWASP ZAP se identificó una alerta informativa denominada *Session Management Response Identified*, relacionada con la detección de las cookies AWSALBCORS y AWSALB en la respuesta HTTP. Según la descripción de la herramienta, esta alerta permite identificar posibles elementos relacionados con la gestión de sesiones y puede utilizarse para configurar automáticamente el mecanismo de reconocimiento de sesión de ZAP. Su aparición no implica, por sí misma, que exista una vulnerabilidad de seguridad. La herramienta clasifica este hallazgo como informativo e indica que no requiere una corrección específica. Por lo tanto, durante esta prueba no se identificaron alertas adicionales relevantes en esta sección, aunque esto no significa que se haya demostrado la ausencia total de vulnerabilidades.


This is a deliberately vulnerable web application designed for testing web vulnerability scanners. Put your scanner to the test!
GIN & JUICE SHOP
PRODUCTS
BLOG
OUR STORY
MY ACCOUNT
SLOE GIN TIMER KIT
$85.78
Order no. 0254809
Order date 10/04/2024
Delivered
Order details
CREATE YOUR OWN COCKTAIL
$84.96

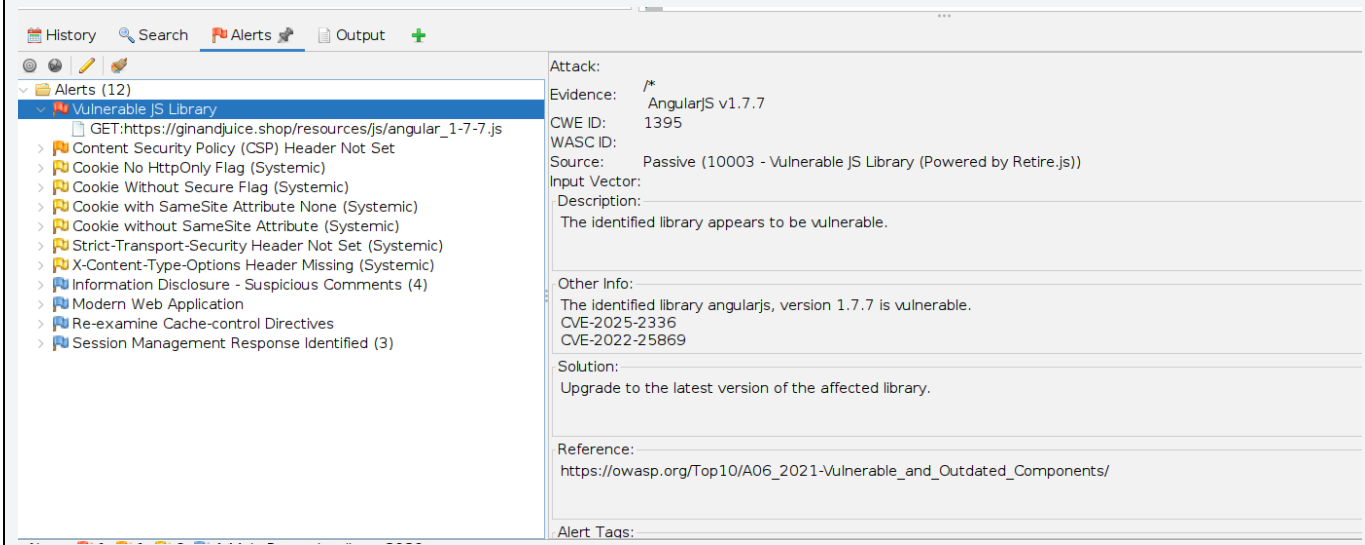

File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
https://ginandjuice.shop
Edit Alert
Session Management Response Identified
URL: https://ginandjuice.shop/my-account
Risk: Informational
Confidence: Medium
Parameter: AWSALBCORS
Attack:
Evidence: AWSALBCORS
CWE ID: 0
WASC ID: 0
Description:
the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
Other Info:
cookie:AWSALBCORS
cookie:AWSALB
Solution:
This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference:
https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
Cancel
Save
History
Search
Alerts
Output
Filter: OFF
Export

2. Alertas encontradas

Se seleccionaron tres hallazgos de todos los encontrados para analizar y detallar, a continuación se dejan las planillas de cada uno con sus descripciones y remediación si así lo requiere.

2.1 Hallazgo 1

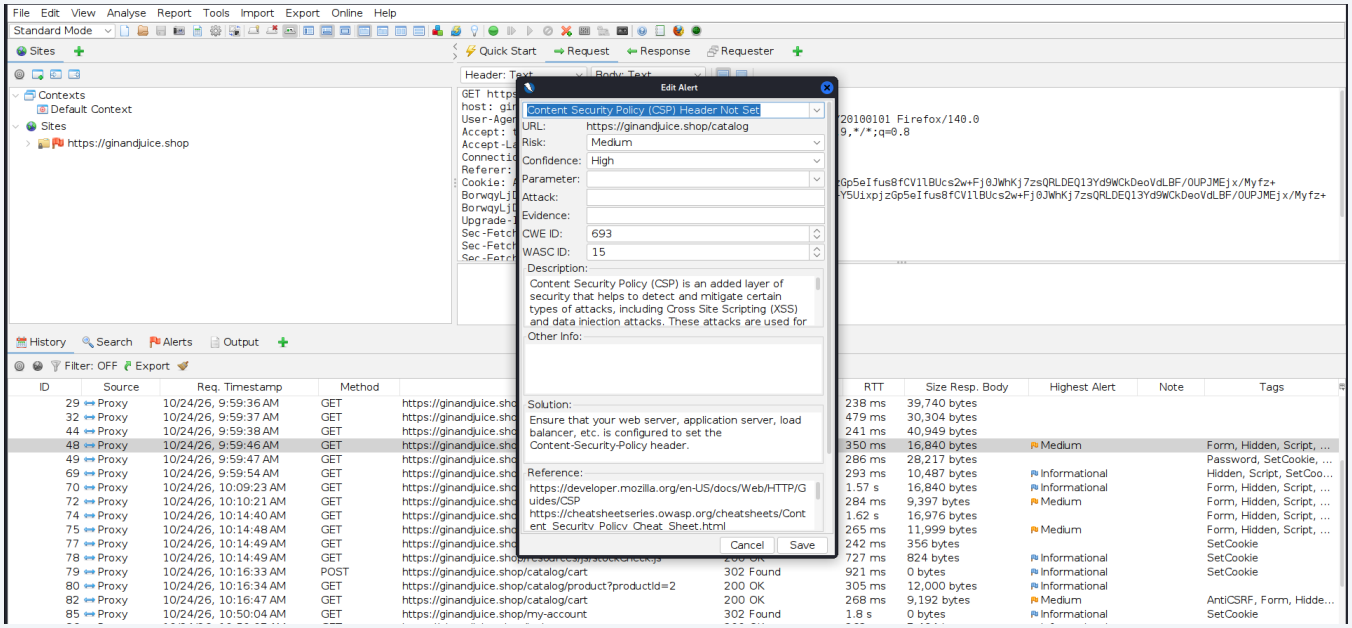
Nombre exacto de la alerta	Vulnerable JS Library.
Riesgo (Risk)	Alta.
Confianza (Confidence)	Media – indica que el grado de certeza de la detección puede no ser absoluto.
URL afectada	https://ginandjuice.shop/resources/js/angular_1-7-7.js
Método HTTP	GET
Parámetro / componente	No aplica. El hallazgo está asociado a una biblioteca JavaScript, no a un parámetro de entrada
Evidencia (Evidence)	OWASP ZAP identificó el recurso angular_1-7-7.js y generó una alerta denominada Vulnerable JS Library, con riesgo alto, confianza media y CWE-1395.
Descripción de ZAP	La aplicación carga una biblioteca JavaScript de terceros identificada como AngularJS 1.7.7. El uso de componentes de software con vulnerabilidades conocidas puede exponer a la aplicación a riesgos de seguridad. Es necesario verificar qué vulnerabilidades concretas afectan a esa versión y si son aplicables al contexto analizado. CWE-1395 corresponde a la dependencia de un componente de terceros vulnerable.
Recomendación de ZAP	Actualizar a la última versión de esta librería.
Evaluación propia	Verificar la versión y las vulnerabilidades asociadas, actualizar la biblioteca a una versión mantenida y corregida compatible con la aplicación, y comprobar que la actualización no introduzca errores de funcionamiento. Revisar también las dependencias y realizar un nuevo análisis de seguridad.



2.2 Hallazgo 2

Nombre exacto de la alerta	Content Security Policy (CSP) Header Not Set
Riesgo (Risk)	Medio
Confianza (Confidence)	Alta. Indica que existe un alto grado de certeza en la detección de la condición informada por la herramienta.
URL afectada	https://ginandjuice.shop/catalog
Método HTTP	GET

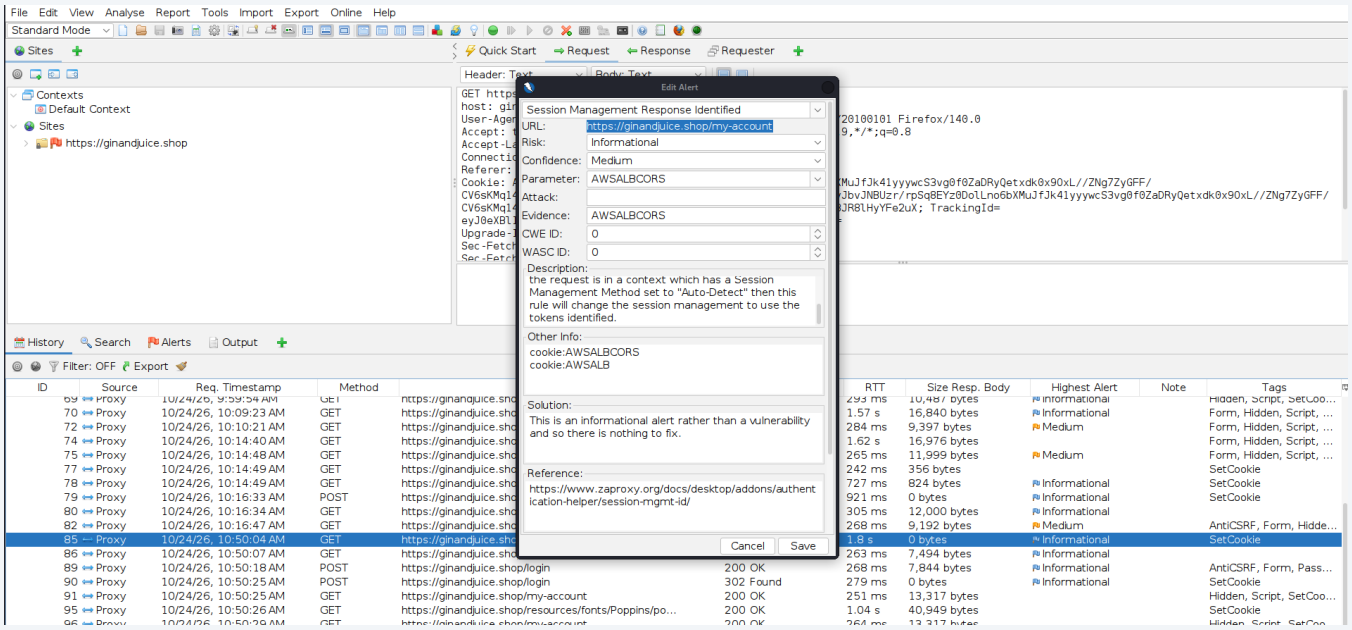
Parámetro / componente	No aplica. El hallazgo está relacionado con la configuración de los encabezados HTTP de la respuesta del servidor.
Evidencia (Evidence)	OWASP ZAP identificó que la respuesta del recurso analizado no incluía el encabezado HTTP Content-Security-Policy y generó una alerta con riesgo medio, confianza alta, CWE-693 y WASC ID 15.
Descripción de ZAP	La respuesta HTTP no contiene el encabezado Content Security Policy (CSP). Esta política permite definir las fuentes desde las cuales la aplicación puede cargar recursos, como scripts, hojas de estilo e imágenes. La ausencia de este encabezado implica que no se dispone de esta capa adicional de protección en la respuesta analizada.
Recomendación de ZAP	Configurar el servidor web, el servidor de aplicaciones o el componente encargado de gestionar las respuestas HTTP para que incluya un encabezado Content-Security-Policy adecuado.
Evaluación propia	Revisar la configuración de seguridad de la aplicación e implementar una política CSP restrictiva, adaptada a los recursos legítimos que necesita el sitio. Probar su funcionamiento para evitar interrupciones en las funcionalidades existentes y repetir el análisis con OWASP ZAP para verificar que el encabezado se encuentre presente. La ausencia de CSP no demuestra por sí sola la existencia de una vulnerabilidad XSS.



2.3 Hallazgo 3

Nombre exacto de la alerta	Session Management Response Identified.
Riesgo (Risk)	Informativo (Informational)
Confianza (Confidence)	Media. Indica que la herramienta identifico con un alto grado de certeza los elementos de la respuesta relacionado con la gestión de sesiones.
URL afectada	https://ginandjuice.shop/my-account
Método HTTP	GET
Parámetro / componente	Cookie de respuesta HTTP. Se identificaron las cookies AWSALBCORS y AWSALB.
Evidencia (Evidence)	OWASP ZAP identificó las cookies AWSALBCORS y AWSALB en la respuesta y generó la alerta *Session Management Response Identified*. La herramienta indica que estos elementos pueden utilizarse para configurar el reconocimiento de sesiones mediante encabezados o cookies.
Descripción de ZAP	La respuesta proporcionada por la aplicación fue identificada como portadora de elementos

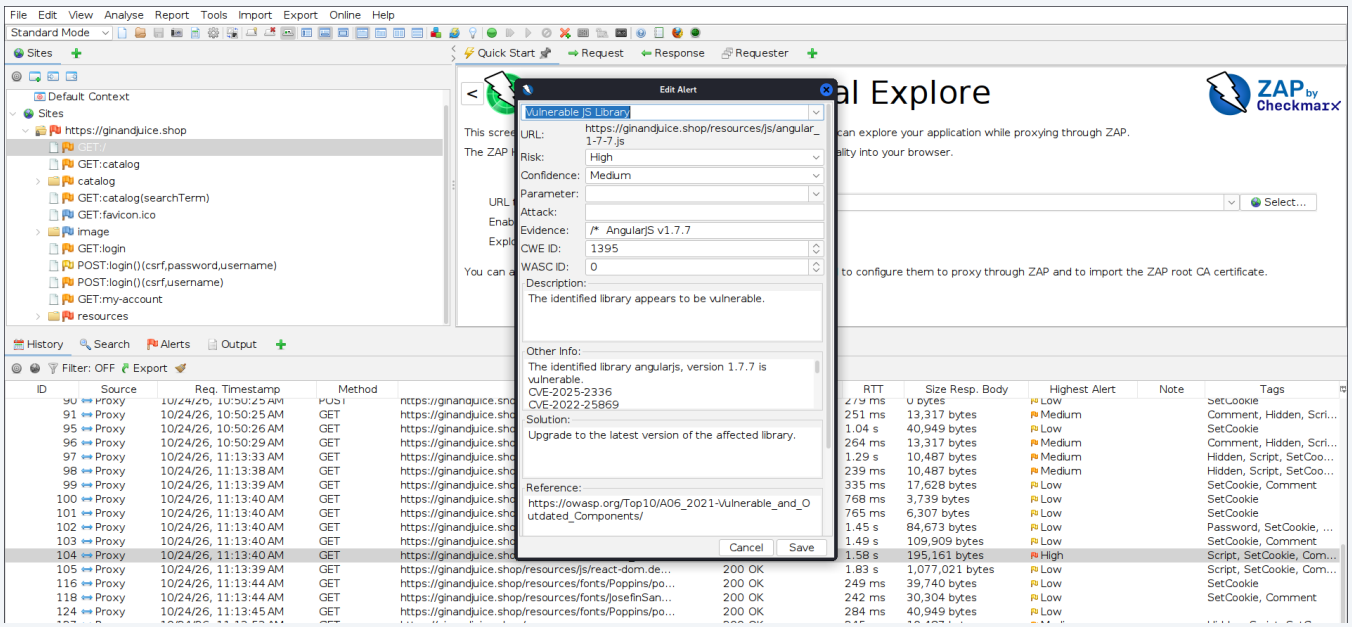
	relacionados con la gestión de sesiones. Esta información puede utilizarse para configurar el mecanismo de gestión de sesiones de OWASP ZAP, especialmente cuando se encuentra habilitada la detección automática. Se trata de una alerta informativa y no constituye, por sí misma, una vulnerabilidad de seguridad.
Recomendación de ZAP	No requiere una corrección específica. La alerta tiene una finalidad informativa y permite reconocer los elementos que podrían intervenir en la gestión de sesiones.
Evaluación propia	Registrar la detección de las cookies como parte del análisis del comportamiento de la aplicación. Si se realizan pruebas adicionales de autenticación y gestión de sesiones, verificar que las cookies estén configuradas adecuadamente y que no se expongan datos sensibles. No se considera necesario aplicar una corrección únicamente por la presencia de estas cookies.



3. Documenta un hallazgo principal

Elegir una de las alertas anteriores y completar los ocho elementos solicitados. Usar evidencia verificable y diferenciar el riesgo asignado por la herramienta del impacto confirmado.

1. Nombre de la alerta	Vulnerable JS Library.
2. Nivel de riesgo	**Riesgo asignado por OWASP ZAP: Alto (High).** **Confianza de la detección: Media (Medium).** La herramienta asignó un nivel de riesgo alto al identificar una biblioteca JavaScript potencialmente vulnerable. La confianza media indica que el hallazgo requiere una comprobación adicional. La clasificación de riesgo corresponde a la evaluación de ZAP y no demuestra, por sí sola, que exista una explotación efectiva en la aplicación analizada.
3. URL o componente afectado	https://ginandjuice.shop/resources/js/angular_1-7-7.js
4. Parámetro afectado	No aplica. El hallazgo está relacionado con una dependencia de software utilizada por la aplicación y no con un parámetro de entrada específico.
5. Evidencia	Durante el análisis de la aplicación con OWASP ZAP se identificó el recurso angular_1-7-7.js, asociado a la alerta *Vulnerable JS Library*. La herramienta clasificó el hallazgo con riesgo alto, confianza media y CWE-1395, relacionado con la dependencia de componentes de terceros vulnerables. Se deja adjunta la captura del hallazgo principal debajo de la ficha.
6. Descripción técnica	La aplicación carga un recurso JavaScript identificado como AngularJS 1.7.7. OWASP ZAP generó una alerta al detectar una biblioteca que puede estar asociada a vulnerabilidades conocidas. El uso de dependencias vulnerables puede introducir riesgos de seguridad cuando una versión contiene fallas que afectan a las funcionalidades utilizadas por la aplicación. Sin embargo, la detección de la biblioteca no demuestra que todas las vulnerabilidades asociadas sean aplicables al sitio ni que puedan explotarse en el contexto analizado. Por este motivo, es necesario verificar la versión exacta, consultar las vulnerabilidades conocidas asociadas y evaluar si las funcionalidades afectadas se encuentran presentes y son accesibles en la aplicación.
7. Impacto potencial	Si se confirma que la biblioteca contiene una vulnerabilidad aplicable y explotable en el contexto de la aplicación, un atacante podría aprovecharla para afectar la seguridad de los usuarios o el funcionamiento del sitio. Las consecuencias concretas dependerían de la vulnerabilidad identificada, de cómo se utilice la biblioteca y de las medidas de protección adicionales existentes. Durante esta práctica no se confirmó la explotación de una vulnerabilidad específica. Por lo tanto, no se puede afirmar que se haya producido acceso no autorizado, robo de información o ejecución de código.
8. Recomendación	• Verificar la versión exacta de la biblioteca y contrastarla con fuentes oficiales y bases de datos de vulnerabilidades conocidas. • Identificar las vulnerabilidades que afectan a esa versión y determinar si son aplicables a las funcionalidades utilizadas por la aplicación. • Actualizar AngularJS a una versión corregida y compatible con la aplicación o, si la tecnología ya no dispone de soporte adecuado, planificar una migración a una alternativa mantenida. • Ejecutar pruebas de regresión para comprobar que la actualización no afecte al funcionamiento del sitio. • Realizar un nuevo análisis con OWASP ZAP para verificar si la alerta continúa apareciendo.



Validación del hallazgo

Estado	Pendiente a Validar con pruebas de explotación.
Fundamento	OWASP ZAP detectó una biblioteca JavaScript potencialmente vulnerable y le asignó un nivel de riesgo alto con confianza media. Sin embargo, con la evidencia recopilada hasta el momento no se ha identificado ni reproducido una vulnerabilidad concreta en la aplicación. Para confirmar el hallazgo es necesario verificar las vulnerabilidades asociadas a la versión detectada y determinar si son aplicables al entorno evaluado.
Limitaciones	Durante la práctica se identificó el recurso JavaScript y se registró la alerta generada por OWASP ZAP. No se documentó una prueba de explotación ni se confirmó el impacto sobre la aplicación. Tampoco se determinó si existen medidas de mitigación adicionales que reduzcan la exposición. Por lo tanto, las posibles consecuencias se describen como riesgos potenciales y no como impactos comprobados.

4. Mis conclusiones:

4.1 ¿Qué aprendí?

Durante esta práctica aprendí a explorar una aplicación web utilizando OWASP ZAP y a observar cómo se comunica el navegador con el servidor mediante solicitudes y respuestas HTTP. Pude identificar métodos como GET y POST, códigos de respuesta como 200 OK y 302 Found, y analizar el comportamiento de distintas funcionalidades, como la búsqueda de productos, el carrito de compras y el perfil de usuario.

También aprendí que OWASP ZAP permite identificar posibles problemas de seguridad mediante alertas clasificadas según su riesgo y nivel de confianza. Sin embargo, comprendí que una alerta no siempre confirma la existencia de una vulnerabilidad explotable, por lo que es necesario analizar su evidencia, verificar el contexto y distinguir entre los riesgos potenciales y los impactos efectivamente comprobados.

Por otra parte, durante la configuración inicial de OWASP ZAP tuve una dificultad al intentar ejecutar la aplicación con privilegios de superusuario mediante sudo su. Esto generó inconvenientes para reconocer correctamente el navegador Firefox. Al revisar la configuración y ajustar la forma de ejecutar la herramienta, logré resolver el problema y continuar con las pruebas. Esta experiencia me permitió comprender que los permisos de ejecución y el entorno del usuario pueden influir en el funcionamiento de las herramientas de seguridad.

Por último, aprendí a documentar los hallazgos de manera estructurada, incluyendo la URL afectada, el componente involucrado, la evidencia, el impacto potencial y las recomendaciones de mitigación.

4.2 ¿Qué fue lo más retador?

Una de las principales dificultades fue interpretar correctamente las alertas generadas por OWASP ZAP y diferenciar aquellas que representan un posible riesgo de seguridad de las que tienen una finalidad informativa. También fue necesario comprender la diferencia entre el nivel de riesgo y la confianza asignados por la herramienta.

Para abordar estas dificultades, revisé la descripción de cada alerta, su evidencia, los componentes involucrados y las recomendaciones proporcionadas por ZAP. Además, comparé los resultados con el comportamiento observado durante la navegación por la aplicación.

Esta experiencia me permitió comprender la importancia de no considerar todas las alertas como vulnerabilidades confirmadas y de documentar las limitaciones de las pruebas realizadas.

4.3 ¿Qué revisaría a continuación?

En una siguiente etapa profundizaría en la validación de los hallazgos identificados, comenzando por la alerta de riesgo alto *Vulnerable JS Library*, para verificar las vulnerabilidades asociadas a la versión de AngularJS detectada y determinar si son aplicables a la aplicación.

También revisaría la configuración de Content Security Policy (CSP), los mecanismos de protección contra ataques Cross-Site Request Forgery (CSRF) en las operaciones del carrito y la gestión de las cookies relacionadas con las sesiones.

Por último, realizaría pruebas adicionales sobre la autenticación, la autorización y el acceso a la información del usuario. Estas tareas permitirían ampliar la cobertura de las pruebas y evaluar si los hallazgos iniciales pueden reproducirse o corregirse.

5. Resumen final del reporte

Para la tabla consolidada, incluí las alertas que vimos con su riesgo, URL, parámetro y evidencia resumida. Agregué las alertas CSRF del producto y del carrito que también documentamos.

Riesgo	Nombre de alerta	URL	Parámetro	Evidencia resumida
Alto	Vulnerable JS Library	/resources/js/angular_1-7-7.js	No aplica	ZAP identificó una biblioteca JavaScript AngularJS 1.7.7. Confianza media.
Medio	Content Security Policy (CSP) Header Not Set	/catalog	Encabezado HTTP	No se detectó el encabezado Content-Security-Policy. Confianza alta.
Medio	Absence of Anti-CSRF Tokens	/catalog/product	Formulario de validación de stock	Se identificó un formulario POST sin un token Anti-CSRF reconocido. Confianza baja.
Medio	Absence of Anti-CSRF Tokens	/catalog/cart	productId, redir	Se identificó un formulario POST del carrito sin un token Anti-CSRF reconocido. Confianza baja.
Informativo	Session Management Response Identified	/resources/js/stockCheck.js*	Cookies AWSALBCORS y AWSALB	ZAP detectó cookies relacionadas con la gestión de sesiones. Confianza alta.
Informativo	Session Management Response Identified	/my-account*	Cookies AWSALBCORS y AWSALB	Se registró la detección de cookies durante el análisis del perfil de usuario. Confianza alta, según la alerta descrita.